

Secure Upload Gateway — Build Plan, Parts 1–5

Sep 22, 2026

Source documents

Only one of the three named sources is available in this conversation. The plan below is built on it, and every place where the other two might have decided something differently is marked as an open question.

Source	Status	Used as
Secure File Upload Security Gateway — Research-Backed Project Specification	Read in full (35 sections)	Primary source of truth for architecture, schema, API, IAM, lifecycle, tests, cost
Secure_File_Upload_Gateway_Full_Literature_Survey.docx	Not attached to this conversation; no file was found in the uploads area	Not used. Attach it and I will reconcile any conflicts before Phase 0
secure-upload-gateway-stage1.md	Not attached	Not used. Same

Facts were verified on 22 September 2026 against official documentation and package registries. Where a page could not be opened the item is marked UNVERIFIED in Part 3 and the plan does not depend on it.

Part 1 — Architecture and decision freeze

The architecture from the specification is frozen unchanged: eight trust zones, four Node.js services sharing one PostgreSQL database, a job queue in PostgreSQL, decisions bound to (bucket, key, version_id, sha256, size), a promotion service that is the only writer of trusted storage, and a write-once ciphertext replica on Google Cloud. Six implementation decisions change because verification showed the original choice is no longer obtainable, deprecated, or incompatible; each is marked CHANGED below with evidence.

1.1 Frozen architecture

```
flowchart LR
    C[Client app<br/>Z1 untrusted] -->|API key / upload token| A[api<br/>Fastify, UPLOAD_ROLE]
    A -->|PutObject If-None-Match| Q[(quarantine bucket<br/>versioned)]
    A --> DB[(PostgreSQL 18<br/>jobs + evidence)]
    S[scanner<br/>SCANNER_ROLE] -->|GetObject by VersionId| Q
    S --> CL[clamd 1.4 LTS<br/>+ YARA-X CLI]
    S --> DB
    P[promotion<br/>PROMOTION_ROLE] -->|GetObject by VersionId,<br/>re-hash, AES-256-GCM| T[(clean bucket<br/>ciphertext)]
    P --> DB
    R[replication<br/>REPLICATION_ROLE] -->|WIF, ifGenerationMatch=0| G[(GCS
```

```

replica<br/>ciphertext)]
R --> DB
D[dashboard<br/>Next.js 16, read-only] -->|JWT| A

```

Invariants that no later phase may weaken:

1. A file reaches the clean bucket only through `services/promotion`, only after an un-superseded ALLOW decision, and only after the promoter has re-fetched the bound version and re-verified SHA-256 and size.
2. `services/api` and `services/scanner` hold no credential that can write the clean bucket or insert a `security_decisions` row.
3. Every state transition of a file writes one hash-chained `audit_events` row in the same database transaction.
4. Every failure path ends in `ERROR`, `QUARANTINE` or `BLOCK`; no code path maps an exception to ALLOW.
5. Clean and replica storage contain only the `SUG1` envelope format; the KEK exists only in the promotion and download processes.

1.2 Decision register

Status values: APPROVED (kept from the specification), CHANGED (replaces a specification decision, evidence given), OPEN (needs your answer before Phase 0).

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
DEC-001	Job queue in PostgreSQL using <code>SELECT ... FOR UPDATE SKIP LOCKED</code> ; no Redis, SQS or Kafka in the MVP	One data store to secure and back up; queue rows are already evidence; throughput needs are tens of files per minute	Redis + BullMQ; SQS; pg-boss library	PostgreSQL SELECT documents SKIP LOCKED	APPROVED	scanner, promotion, replication
DEC-002	Local S3-compatible store is LocalStack Community (<code>localstack/localstack:2026.08.3</code>), not MinIO	The MinIO repository is archived, community binaries are source-only, and the <code>minio/minio</code> Docker Hub	MinIO built from archived source (unpatched CVE, maintenance burden); AIStor Free (proprietary	MinIO README ; LocalStack v3.7.0 ; LocalStack S3 docs ; SeaweedFS S3 API	CHANGED (spec said MinIO)	Compose, packages/s storage, local IAM tests

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
		repository returns 404 as of September 2026. LocalStack Community supports versioning and If-None-Match on PutObject (since v3.7.0) and If-Match (4.0.3)	licence file, single node); SeaweedFS 4.45 (Apache-2.0, versioning, conditional headers; lighter but a less faithful S3 emulation); Garage (no versioning); RustFS (pre-release)			
DEC-003	Local privilege separation is enforced by <i>application credentials</i> (each service has only its own access key pair) and verified for real on AWS; LocalStack Community is not relied on to enforce IAM policy	IAM policy enforcement in LocalStack is a paid-tier feature to the best of current knowledge (VERIFICATION REQUIRED in Phase 2); SeaweedFS offers per-identity bucket actions if enforcement locally becomes mandatory	Run IAM negative tests only on AWS (chosen); switch to SeaweedFS with - <code>s3.config</code> identities	LocalStack docs above	CHANGED (spec ran IAM tests on MinIO users)	tests/security/iam

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
DEC-004	Dashboard is Next.js 16 (App Router, TypeScript, Tailwind 4, shadcn/ui), served as a separate container that only calls the Fastify API	You asked for Next.js; the specification chose React+Vite to avoid a second server. The trade-off is accepted with two constraints: no security logic, no direct database access, and all data fetching from the browser or from Route Handlers that forward the user's JWT; the Next server holds no secrets	React + Vite static SPA (spec)	Next.js 16 installation (Node 20.9+, Turbopack default, <code>next.config.ts</code>); Tailwind v4 + Next ; shadcn Next install	CHANGED	apps/dashb oard
DEC-005	PostgreSQL 18 (postgres: 18-alpine)	18.6 is a year old, supported to November 2030, adds native uuidv7() for time-ordered IDs; all syntax	PostgreSQL 16 (spec; supported to November 2028, no advantage now); 17	PostgreSQL releases ; PG 18 release notes	CHANGED (spec said 16; your brief also said 16 — say if you want 16 kept)	migrations, Compose

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
		used (identity columns, SKIP LOCKED, pgcrypto digest, citext, advisory locks) is unchanged. Note: PG 18 generated columns default to VIRTUAL; the schema uses none				
DEC-006	Metrics library is @prometheus-io/client 0.16.x	prom-client 15.1.3 is marked deprecated on npm in favour of @prometheus-io/client	prom-client	npm registry deprecation notice (Part 3)	CHANGED	packages/shared/metrics
DEC-007	TypeScript pinned to 6.0.3; ESLint 10 flat config; typescript-eslint 8.70	TypeScript 7.0 (native port) ships no programmatic API yet and typescript-eslint's peer range is <6.1.0; ESLint 9 reached end	TS 7 with typescript @npm:@typescript/typescript6 alias; TS 5.9.3	TypeScript 7.0 announcement ; typescript-eslint versions ; ESLint v10	CHANGED (spec said TypeScript 5)	all packages

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
		of life on 6 August 2026				
DEC-008	Node.js 24 LTS everywhere ; images node:24-alpine; pnpm 12 installed with npm i -g pnpm@12 in Dockerfiles (Corepack is still bundled in Node 24 but removed from Node 25+)	Active LTS until October 2026, maintenance to April 2028; every chosen library requires Node ≥ 22	Node 26 (Current, LTS from 28 October 2026)	Node.js releases ; Corepack README	APPROVED	all
DEC-009	Fastify 5.12 with @fastify/type-provider-zod 1.0 and zod 4.6 ; raw application/octet-stream upload body; no multipart parser	Fastify 5 is the current stable, tested on Node 24; the scoped type provider is the org-official package and requires zod ≥ 4.2	Express + multer (10 advisories in 2025–2026); unscoped fastify-type-provider-zod	Fastify LTS ; npm registry	APPROVED	services/api
DEC-010	ClamAV 1.4.6 LTS image clamav/clamav:1.4.6, configured	1.4 is the LTS line (EOL 15 August 2027); the official	ClamAV 1.5.4 (regular release, shorter support);	ClamAV EOL policy ; ClamAV Docker ; clamd	APPROVED (version pinned)	services/scanner, Compose

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
	through CLAMD_CONF _<Option> environment variables; in-house 60-line INSTREAM client	image documents env-var overrides; the clamscan npm package has had no release since October 2024	clamscan npm	protocol		
DEC-011	YARA-X 1.20.0 CLI (yr scan - -output-format ndjson) invoked as a subprocess; results parsed from NDJSON, never from the exit code	YARA-X has no distinct "match found" exit code (only 0 or 1 for error); the official @virustotal/yara-x npm package is a WebAssembly build with no production-readiness statement	@virustotal/yara-x WASM (fallback if subprocess cost matters); classic YARA (maintenance mode)	YARA-X CLI; cli/src/main.rs	APPROVED (invocation detail added)	services/scanner
DEC-012	Application-level envelope encryption, AES-256-GCM, per-file DEK, KEK from a Docker secret	As in the specification; verified createCipheriv('aes-256-gcm', key, iv, {authTagLength: 16}) and that authenticity	KMS-only; SSE-KMS only	Node.js crypto ; SP 800-38D	APPROVED	packages/crypt

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
	locally and SSM SecureString in the cloud; KMS optional	is established only at decipher.final()				
DEC-013	Terraform 1.16 with AWS provider 6.x and Google provider 8.x; bootstrap IAM access keys are created with the AWS CLI, not Terraform	AWS provider 6 is current; aws_iam_access_key writes the secret to state in plaintext and aws_ssm_parameter SecureString values also land in state unless value_wo is used	OpenTofu 1.12 (MPL-2.0, drop-in) if the BUSL licence is a concern; pgp_key on aws_iam_access_key	AWS provider 6 upgrade guide ; aws_iam_access_key	APPROVED (key handling added)	infrastructure/
DEC-014	The GCP project is created once by hand (gcloud projects create) and referenced by Terraform, not created by Terraform	The Google provider docs say google_project must belong to an Organization, while the API allows a parentless project on a personal account; Terraform creation of a parentless project is	google_project resource	google_project ; Creating projects	APPROVED	infrastructure/gcp

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
		UNVERIFIED				
DEC-015	Workload Identity Federation from the laptop uses STS session credentials exported as AWS_ACCESS_KEY_ID, AWS_SECRET_ACCESS_KEY, AWS_SESSION_TOKEN, AWS_REGION ; no IMDS, no Google service-account key	Google's auth libraries read AWS environment variables before falling back to the metadata server; the credential configuration file contains no secrets	Executable-sourced credentials; service-account key file (rejected)	WIF with AWS; AIP-4117	APPROVED	services/replication
DEC-016	The DenyOverwrite bucket-policy statement (Null:s3:if-none-match) is applied to both quarantine and clean buckets; CopyObject is never used	AWS documents that enforcing s3:if-none-match makes CopyObject fail (403 without headers, 501 with); the promoter streams through itself and never copies server-side	Skip the statement and rely on code	Enforcing conditional writes	APPROVED (constraint recorded)	bucket policies, promotion

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
DEC-017	Billing alarm on AWS/Billing Estimated Charges is created with a us-east-1 provider alias after "Receive Billing Alerts" is switched on manually in the console	The metric exists only in us-east-1 and needs the console preference first	Budgets only	Billing alarm docs	APPROVED	infrastructure/aws/budgets.tf
DEC-018	Local TLS: the API listens on plain HTTP inside the Compose network; a Caddy 2.11 container with tls internal is added only in the tls Compose profile	Caddy cannot install its root CA into the host trust store from a container; plain HTTP keeps CI simple. Cloud demo still uses TLS to AWS and GCP from the SDKs	Always-on Caddy	Caddy tls directive	APPROVED (spec said Caddy always on; profile-gated now)	Compose
DEC-019	Local GCS emulation is fsouza/fake-gcs-server:1.56.1 through the JSON API only	It honours ifGenerationMatch, generations and declared CRC32C on JSON	Google storage-testbench	fake-gcs-server upload.go	APPROVED	Compose, packages/storage

ID	Decision	Reason	Alternatives considered	Evidence	Status	Impacted components
		uploads; the XML path does not				
DEC-020	Argon2id via native argon2 0.45 (prebuilt Node-API binaries); @node-rs/argon2 is the fallback if a platform lacks a prebuild	Both verified on Node 24	bcrypt	npm registry, node-argon2 README	APPROVED	services/api
DEC-021	ZIP inspection with yauzl 3.4 (lazy central-directory reading) plus own structural checks; @zip.js/zip.js 2.17 is the alternative	yauzl is maintained (June 2026 release) and streams entries without extraction	@zip.js, unzipper, node-stream-zip	npm registry	APPROVED	packages/security-engine/archive
DEC-022	Vitest 5, k6 2.2, testcontainers 12 optional	Current versions; Vitest 5 defaults clearMocks : true	Jest	Vitest 5 blog	APPROVED	tests/

1.3 Open questions to settle before Phase 0

ID	Question	Default if unanswered
----	----------	-----------------------

ID	Question	Default if unanswered
OPEN-1	Keep PostgreSQL 18 (DEC-005) or revert to 16 as your brief states?	18
OPEN-2	LocalStack Community (S3 fidelity, larger image, IAM likely not enforced) or SeaweedFS (lighter, per-identity actions) for local storage?	LocalStack, re-evaluated after the Phase 2 spike
OPEN-3	Attach the two missing source documents so conflicts can be reconciled?	Proceed on the specification alone
OPEN-4	Windows development host: Docker Desktop with WSL 2 backend assumed; confirm	Assumed

1.4 Final technology stack

Layer	Choice	Version
Runtime	Node.js	24 LTS (image node:24-alpine)
Package manager	pnpm	12.5
Language	TypeScript	6.0.3 (pinned)
API	Fastify, @fastify/type-provider-zod, @fastify/rate-limit, @fastify/helmet, @fastify/cors, @fastify/cookie, @fastify/swagger	5.12 / 1.0 / 11.2 / 13.1 / 11.3 / 11.1 / 9.8
Validation	zod	4.6
Database	PostgreSQL; pg; kysely; node-pg-migrate	18 / 8.23 / 0.29 / 9.0
Logging and metrics	pino; @prometheus-io/client	10.3 / 0.16
Auth	jose (EdDSA); argon2	6.2 / 0.45
Files	file-type; yauzl; sharp	22.1 / 3.4 / 0.35
Scanning	ClamAV; YARA-X	1.4.6 / 1.20.0
Cloud SDKs	@aws-sdk/client-s3, client-sts, client-ssm, credential-providers;	3.1137 / 8.2 / 11.1

Layer	Choice	Version
	@google-cloud/storage; google-auth-library	
Local emulation	LocalStack Community; fake-gcs-server	2026.08.3 / 1.56.1
Dashboard	Next.js; React; Tailwind; shadcn	16.3 / 19.3 / 4.3 / CLI 4.21
Infra	Docker Compose v2; Terraform; AWS provider; Google provider	current / 1.16 / 6.58 / 8.1
Tests	Vitest; k6; ESLint; typescript-eslint	5.0 / 2.2 / 10.11 / 8.70

Part 2 — Complete implementation roadmap

The 66 requested phases collapse into 36 phases, because several of them are one pull request's worth of work and splitting them would create phases with no independent Definition of Done. Nothing is dropped: the mapping table shows where each of the 66 lands. Each phase gets its full contract (the 26 fields A–Z) when you say "START PHASE n"; here every phase has its objective, inputs, outputs, dependencies, security and research objective, Definition of Done and commit message, which is enough to plan and to review scope.

2.1 Mapping of the 66 requested phases

Requested	Lands in	Why
0 Architecture freeze	P0	As requested
1 Repository, 2 Docker Compose	P1, P2	Kept separate: P2 includes the storage-emulator spike that decides OPEN-2
3 Database and migrations, 4 Config and secrets	P3, P4	As requested
5 Fastify foundation, 44 Health and readiness	P5	Health endpoints are part of the first bootable server
6 Application authentication, 7 RBAC	P6 (API keys), P7 (users, JWT, RBAC)	As requested
8 Upload session, 9 Quarantine storage, 10 Streaming and limits	P8 (session + policy pre-check), P9 (storage provider + quarantine bucket), P10 (streaming PUT)	As requested

Requested	Lands in	Why
11 Extension, 12 MIME, 13 Magic bytes, 14 Filename and key	P11	One pure package, one test table; separate phases would each be under a day
16 SHA-256 identity	P12	Placed before scanning because every later phase reads the identity
21 Job queue, 22 Worker architecture	P13	The queue helper and the first worker loop are one deliverable
17 ClamAV, 52 EICAR tests	P14	The EICAR test is the acceptance test of the ClamAV phase
18 YARA-X, 53 YARA tests	P15	Same reasoning
15 Archive inspection, 51 zip-bomb tests	P16	Same
19 Findings model	P17 (findings persistence and format checks: PDF, OOXML, image, polyglot)	Adds the format checks the spec lists under step 15
20 Decision engine	P18	As requested
25 AES-256-GCM, 26 Envelope and keys	P19	One packages/crypto deliverable
23 Exact-version promotion, 24 TOCTOU protection, 27 Clean storage	P20	These are one code path; promotion without binding is the baseline, built in P32
29 Audit logging, 30 Hash chain	P21	Built early (P3 creates the tables) and completed here with checkpoints
28 IAM separation (local), 49 IAM negative tests	P22 (local credentials + DB roles), P29 (AWS/GCP)	Local first, cloud after deployment
47 Unit, 48 Integration, 55 End-to-end	P23	Tests are written in every phase; P23 assembles the lifecycle and chaos suites and the SQL invariant
31 AWS S3, 58 AWS deployment, 60 Terraform	P24 (account hygiene and budgets), P25 (Terraform S3, IAM, SSM)	Budgets before any other resource

Requested	Lands in	Why
32 GCS replication, 33 Cloud IAM, 59 GCP deployment	P26 (Terraform GCS, WIF), P27 (replication service), P28 (audit checkpoints to both clouds)	As requested, ordered so the service is built against real GCS
45 Metrics and observability	P30	After the cloud path exists, so metrics cover it
34–43 Dashboard	P31 (foundation + auth), P33 (overview, files, file detail, scans, decision detail), P34 (review, policies, integrity, audit, access)	Three phases instead of ten; each page is a checklist item inside
57 Baseline comparison, 50 TOCTOU harness	P32	The baseline promoter and the race harness are one experiment artifact
46 Security corpus, 54 API security tests	P35 (corpus generators + full 80-test matrix)	The corpus is needed by P14–P18 in part; P35 completes it and freezes it
56 Performance	P36	As requested
61 Hardening, 62 Production-like	P37	Container hardening, dependency scanning, Level C notes
63 Research evaluation, 66 Evidence collection	P38	One reproducible <code>make reproduce</code>
64 Documentation, 65 Final demonstration	P39	As requested

2.2 Phase contracts (summary form)

Each entry: objective · inputs → outputs · depends on · security objective · research objective · Definition of Done · commit. Branch name is `phase/<n>-<slug>`; every phase ends with one squash-merged pull request so that reverting a phase is one `git revert`.

P0 — Architecture freeze and decisions. Confirm Part 1, answer OPEN-1–4, write `docs/adr/0001-0010`, threat model and the T1–T8 taxonomy, `docs/decision-register.md` and `docs/risk-register.md` as living files. → Depends on nothing. Security: threat model reviewed. Research: hypotheses H1–H5 frozen with their statistics. DoD: ADRs merged; reading list for the four unverified papers assigned. Commit: `docs(adr): freeze architecture and decisions`.

P1 — Repository and monorepo. `pnpm 12 workspace`, TypeScript 6.0.3 strict base config, ESLint 10 flat config with `typescript-eslint 8.70` and `eslint-plugin-boundaries 7.2`, Vitest 5, Prettier, `.editorconfig`,

.gitattributes (LF), CI workflow running lint, typecheck, unit tests, gitleaks. → Outputs: empty services/api, packages/shared that build. Security: secret scanning on from the first commit. DoD: CI green on empty workspace; a deliberate boundary violation fails lint. Commit: chore: scaffold monorepo.

P2 — Development environment and Docker Compose. Compose with postgres:18-alpine, localstack/localstack:2026.08.3 (S3 only, SERVICES=s3), fsouza/fake-gcs-server:1.56.1, init containers that create the three buckets with versioning, plus the **storage assumption spike** (packages/storage/test/assumptions.test.ts): PutObject returns VersionId; If-None-Match: * returns 412 on repeat; GetObject by old VersionId after overwrite returns the old bytes; ChecksumAlgorithm: SHA256 round-trips; fake-gcs honours ifGenerationMatch: 0. If LocalStack fails any assertion, switch to SeaweedFS in this phase and record it in DEC-002. Security: deploy.resources.limits, read_only, cap_drop, no-new-privileges on every service from the start. DoD: docker compose up -d healthy; spike passes; OPEN-2 closed. Commit: chore(compose): local environment with S3 and GCS emulators.

P3 — PostgreSQL schema and migrations. node-pg-migrate 9 (ESM) with plain SQL files 001_types.sql ... 009_roles_grants.sql; the sixteen tables from the specification (users, applications, api_keys, security_policies, refresh_tokens, upload_sessions, files, file_versions, cloud_objects, scan_jobs, scan_results, security_decisions, promotion_jobs, replication_jobs, audit_events, audit_checkpoints) with uuidv7() defaults; forbid_mutation trigger; audit_append(); six database roles. Kysely types generated from the schema. Security: append-only evidence and role grants exist before any service code. DoD: migrate from empty; db-01 role test passes; CHECK (storage_version_id NOT IN ('', 'null')) proven. Commit: feat(db): schema, audit chain and roles.

P4 — Configuration and secrets. zod-validated environment loader (packages/shared/config.ts) that refuses to start on a missing variable; Docker file secrets (/run/secrets/*) for pepper, JWT Ed25519 key, KEK, checkpoint key, per-service storage keys; scripts/gen-secrets.sh; .env.example with names only. Security: no secret in git, image or bundle; gitleaks proves it. DoD: missing secret aborts start with a clear message; secrets are never logged (redaction unit test). Commit: feat(config): validated config and secret loading.

P5 — Fastify API foundation, health and readiness. App factory, request-ID, problem+json errors, @fastify/helmet, @fastify/rate-limit, @fastify/swagger generating docs/openapi.json, /healthz, /readyz (DB + storage reachability without detail). DoD: curl /readyz returns 200 only when PostgreSQL and LocalStack answer; OpenAPI file generated in CI. Commit: feat(api): server foundation with health checks.

P6 — Application authentication and API keys. sug_<env>_<prefix8>_<secret43> format, HMAC-SHA-256 with pepper, timingSafeEqual, scopes, revocation, POST /applications, POST /applications/:id/api-keys, DELETE /api-keys/:id, scripts/seed.ts. Security: constant-time verification; AUTH_FAILED audited. DoD: authz-01, authz-02 pass. Commit: feat(auth): application API keys.

P7 — Users, JWT and RBAC. argon2id users, POST /auth/login, rotating refresh tokens in HttpOnly; Secure; SameSite=Strict cookie, EdDSA access tokens with aud=sug-dashboard, roles admin | analyst | auditor, requireRole() guard. Security: RFC 8725 validation (fixed algorithm, iss, aud,

exp, typ); lockout after 5 failures. DoD: authz-04 (JWT abuse) and authz-06 (role denial) pass. Commit: feat(auth): dashboard users, JWT and RBAC.

P8 — Policy engine and upload session. packages/policy-engine (zod strict schema sug.policy/v1, canonical JSON + SHA-256, presets, precheck(), filename normaliser), POST /policies, GET /policies/:id, PUT /policies/:id (new version), POST /upload/session issuing the single-use EdDSA upload token (aud=sug-upload, jti, sid, 10 min). DoD: policy-01, policy-02, val-02, val-05, val-09 pass at API level. Commit: feat(upload): policies and upload sessions.

P9 — Storage provider and quarantine bucket. packages/storage StorageProvider interface with S3Provider (AWS SDK v3, works against LocalStack and AWS), putIfAbsent() (IfNoneMatch: '*', ChecksumAlgorithm: 'SHA256'), getByVersion(), head(); per-service credentials from environment; quarantine key scheme incoming/<app_id>/<upload_id>. DoD: spike from P2 passes through the provider; error mapping (412 → AlreadyExists, 404 NoSuchVersion → VersionMissing) unit-tested. Commit: feat(storage): S3 provider with write-once and version reads.

P10 — Streaming upload and resource limits. PUT /upload/:id: atomic session claim, raw body stream, byte counter and SHA-256 tee, abort above min(maxFileSize, declared), 30 s idle timeout, 202 with fileId; transaction inserting files, file_versions, scan_jobs; GET /upload/:id/status. Security: no buffering, no multipart, no temp files. DoD: val-10 (lying size) returns 413 with flat RSS; authz-05 (token reuse race) yields exactly one object; file_versions.storage_version_id populated. Commit: feat(upload): streaming quarantine upload.

P11 — Deterministic validators. packages/security-engine: filename safety, extension allowlist and double-extension denylist, declared MIME, magic detection with file-type 22 (fileTypeFromBuffer on the first 4,100 bytes) and libmagic (file --mime-type -b in the scanner image), type-map.ts canonical types, consistency rule, size rule. Pure functions, table-driven tests. DoD: val-03, val-04, val-06, val-07, val-08, val-12 pass as unit tests; 100% branch coverage on type-map consistency. Commit: feat(security-engine): filename, extension, MIME and magic validators.

P12 — SHA-256 artifact identity. ArtifactIdentity type and helpers in packages/shared; ingest hash at upload; scanned_* columns on findings; identity comparison utility with timingSafeEqual; identity shown in GET /upload/:id/status. Research: this is the object the whole paper is about; unit tests document each field's source. DoD: identity captured at upload and readable; comparison utility tested for every mismatch class. Commit: feat(identity): bound artifact identity.

P13 — PostgreSQL job queue and worker architecture. packages/shared/jobs.ts (claim() with FOR UPDATE SKIP LOCKED, backoff, reaper, DEAD after max_attempts), services/scanner skeleton that claims scan_jobs, fetches by VersionId into a per-job tmpfs directory, hashes, and persists a placeholder finding. DoD: two workers never claim one job (test with 50 jobs and 4 workers); a killed worker's job is re-queued by the reaper within 5 minutes. Commit: feat(worker): PostgreSQL job queue and scanner loop.

P14 — ClamAV integration and EICAR test. clamav/clamav:1.4.6 service on network scan with CLAMD_CONF_* overrides (StreamMaxLength 55M, MaxFileSize 55M, MaxScanSize 200M, MaxRecursion 10, MaxFiles 2000, MaxScanTime 60000, AlertExceedsMax yes, AlertEncrypted yes, AlertEncryptedArchive yes, MaxThreads 4, ConcurrentDatabaseReload no), 4 GB limit, clamdcheck.sh

health; packages/scanner/clamav.ts INSTREAM client (zINSTREAM\0, 4-byte big-endian chunks, zero-length terminator, only stream: OK is clean); signature-age gauge. DoD: scan-01 (EICAR assembled at runtime), scan-02, scan-07 (kill clamd mid-scan → ERROR, never ALLOW), scan-09, scan-10 pass. Commit: feat(scanner): ClamAV INSTREAM scanning.

P15 — YARA-X integration. yr 1.20.0 binary in the scanner image; packages/scanner/yara.ts running yr scan --output-format ndjson --timeout 30 --print-meta rules/ <file>, parsing NDJSON, rule meta tags severity and confidence; rules directory versioned, signature_version = git SHA; benign-corpus gate fp-01 before a rule may block. DoD: scan-03 passes; a rule with a syntax error fails the build. Commit: feat(scanner): YARA-X rules.

P16 — Archive inspection and zip-bomb tests. packages/security-engine/archive: yauzl lazy read, two-phase budgets, overlap detection, structural checks (single EOCD, central equals local, no duplicates, methods 0/8, no encryption flag, path and symlink rules, CRC), worker-thread memory cap, OOXML always inspected. DoD: arc-01 to arc-09 pass; arc-02 completes under 10 s with worker RSS under 256 MB. Commit: feat(security-engine): safe ZIP inspection.

P17 — Findings model and format checks. Finalise scan_results writing (one row per check with identity), reason-code table, PDF active-content check (qpdf normalise + keyword scan), OOXML macro and external-relationship check, image trailing-data and embedded-signature check, basic polyglot check, GET /scans/:id. DoD: scan-04, scan-05, scan-06, poly-01, poly-02, poly-03 pass; poly-04 recorded as a documented miss. Commit: feat(scanner): findings persistence and format checks.

P18 — Deterministic decision engine. packages/decision-engine: decide(policy, fileVersion, findings), rules R1–R7 with the R2/R3 precedence, risk score lookup, explainable record sug.decision/v1, property test "any ERROR on a required check never yields ALLOW", GET /security-decisions/:id, review endpoint. DoD: 100% branch coverage; property test passes 10,000 cases; policy-03 passes end to end. Commit: feat(decision): deterministic decision engine.

P19 — AES-256-GCM envelope encryption and key management. packages/crypto: SUG1 format, per-file DEK and nonce, AAD binding, LocalKeyProvider (Docker secret / SSM), KmsKeyProvider stub behind the interface, verify-before-release decrypt. DoD: crypto-01 to crypto-04 pass; test vectors stored; nonce-uniqueness test over 10,000 encryptions. Commit: feat(crypto): envelope encryption.

P20 — Bound promotion and trusted clean storage. services/promotion: decision loop, promotion_jobs insert function that checks ALLOW and non-supersession, re-fetch by bound_storage_version_id, re-hash and size compare, encrypt to temp, putIfAbsent to objects/<app_id>/<file_id>, cloud_objects row, audit in one transaction; GET /files/:id download with verify-before-release and safe headers; DELETE /files/:id. DoD: toctou-01 to toctou-04 pass; int-01 invariant returns zero orphans after the suite; authz-07 passes. Commit: feat(promotion): version- and hash-bound promotion.

P21 — Audit chain completion. Chain verifier packages/audit/verify.ts, GET /security-events, GET /audit/verify, checkpoint signer (Ed25519) writing to the local audit bucket, every action code

from the specification wired in. DoD: audit-01 to audit-03 pass; tamper-as-superuser detected at the right seq. Commit: feat(audit): chain verification and checkpoints.

P22 — Local privilege separation. One access-key pair per service in LocalStack (or SeaweedFS identities if OPEN-2 chose it), six PostgreSQL roles wired to the six services, network segmentation (edge, data, store, scan, egress), scanner container read-only and egress-less. DoD: db-01 passes; scanner container cannot reach the internet (test with wget inside it); each service starts with only its own credentials. Commit: feat(iam): local credential and network separation.

P23 — Integration, chaos and end-to-end suites. tests/integration/lifecycle.test.ts (upload → promoted, upload → blocked, upload → review → allow), chaos.ts (kill scanner, kill DB, stop storage mid-flight, duplicate jobs, 1,000 concurrent uploads), invariants.sql run after every suite, packages/sdk client used by tests. DoD: H2 pre-check: zero invariant violations across all chaos runs locally. Commit: test: lifecycle, chaos and invariant suites.

P24 — AWS account hygiene and cost guardrails. Manual console steps (root MFA, no root keys, billing alerts preference, admin IAM identity with MFA), AWS CLI v2 install and aws sts get-caller-identity, Terraform budgets.tf (aws_budgets_budget \$5 and \$0.01, aws_cloudwatch_metric_alarm on EstimatedCharges via us-east-1 alias, aws_ce_anomaly_monitor + subscription). DoD: a test budget notification e-mail received; terraform plan shows no compute, no NAT, no data events. Commit: feat(infra): AWS budgets and billing alarms.

P25 — AWS storage and IAM with Terraform. aws_s3_bucket × 3 with random_id suffix, aws_s3_bucket_versioning, aws_s3_bucket_lifecycle_configuration, aws_s3_bucket_public_access_block (all four true), aws_s3_bucket_ownership_controls, aws_s3_bucket_server_side_encryption_configuration, aws_s3_bucket_object_lock_configuration (audit bucket, object_lock_enabled = true on the bucket), aws_s3_bucket_policy with the explicit denies, seven aws_iam_role + aws_iam_policy + attachments, seven bootstrap aws_iam_user with sts:AssumeRole only (access keys created by CLI, DEC-013), aws_ssm_parameter SecureString KEK using value_wo; packages/storage/aws-credentials.ts with fromTemporaryCredentials refreshing hourly; Compose profile cloud. DoD: full lifecycle against real S3; toctou-05 (write-once by policy) passes; CloudTrail event history shows role sessions. Commit: feat(infra): AWS buckets, roles and policies.

P26 — Google Cloud storage and Workload Identity Federation. Manual gcloud projects create + billing link + budget (DEC-014); Terraform google_project_service, google_storage_bucket (us-east1, uniform access, public access prevention enforced, versioning, retention 30 days unlocked, soft delete default), google_service_account × 2, google_iam_workload_identity_pool + _provider with aws { account_id } and attribute condition on the replication role, google_service_account_iam_member (roles/iam.workloadIdentityUser for the principalSet), google_storage_bucket_iam_member (objectCreator, objectViewer), google_billing_budget; gcloud iam workload-identity-pools create-cred-config ... --aws. DoD: from the laptop with STS env vars, gcloud storage or a 10-line Node script writes one object as sug-replicator and cannot read it back. Commit: feat(infra): GCS replica bucket and federation.

P27 — Replication service. `services/replication`: claim `replication_jobs`, stream ciphertext by clean `VersionId`, `file.save(stream, {preconditionOpts: {ifGenerationMatch: 0}, validation: 'crc32c'})`, SHA-256 compare with `cloud_objects.sha256_cipher`, record generation, backoff over 24 h; verify-replica sampling script under `sug-auditor`. DoD: promoted file appears in GCS within 60 s; iam-08 passes; GCS outage simulation leaves the primary path green. Commit: `feat(replication): write-once ciphertext replica`.

P28 — Cross-cloud audit checkpoints and restore drill. Checkpoints written to the S3 Object Lock bucket and to GCS every 10 minutes; `scripts/restore-from-gcs.ts`; `scripts/cloud-cleanup.ts`; `scripts/cloud-inventory.ts`. DoD: audit-04 (checkpoint deletion denied) passes; restore drill recovers a file into an empty bucket with a matching plaintext hash. Commit: `feat(audit): cross-cloud checkpoints and restore`.

P29 — Cloud IAM negative tests and blast radius. `tests/security/iam/blast-radius.ts` assuming each of the seven roles and attempting the 40-action list on AWS and GCS; cross-check against CloudTrail; tighten policies until zero forbidden successes. DoD: iam-01 to iam-10 pass on real clouds; H4 dataset produced. Commit: `test(iam): cloud blast-radius suite`.

P30 — Metrics and observability. `@prometheus-io/client` registry in `packages/shared/metrics.ts`, the 17 `sug_*` metrics, `/metrics` bound to the data network, Prometheus + Grafana in profile obs, the nine alert rules, alert drill. DoD: every required metric visible; `HashOrVersionMismatch` and `AuditChainBroken` fire in a drill. Commit: `feat(observability): metrics and alerts`.

P31 — Dashboard foundation and authentication. `apps/dashboard` with `create-next-app` (Next 16, TypeScript, Tailwind 4, App Router), `shadcn init`, layout shell, login page calling `POST /auth/login`, token kept in memory and refreshed through the cookie, `proxy.ts` guarding `/dashboard/*`, typed API client generated from `docs/openapi.json`. Security: no server-side secrets; CSP via `next.config.ts` headers; API base URL from public env. DoD: login, refresh, logout and role-aware navigation work; dashboard container image contains no secret. Commit: `feat/dashboard): Next.js foundation and auth`.

P32 — Baseline promoter and TOCTOU attack harness. `tests/security/toctou/baseline-promoter.ts` (P0 key-only, P1 version-only, P2 hash-only), `race.ts` with deterministic hook points and random delays, 1,000 trials per promoter per window, CSV output, run on LocalStack and on S3 with the write-once policy removed on a scratch bucket. DoD: toctou-06 produces the H3 table; the bound promoter shows zero unscanned promotions. Commit: `test(toctou): baseline promoters and race harness`.

P33 — Dashboard: overview, files, file detail, scans, decisions. `/dashboard`, `/dashboard/files`, `/dashboard/files/[id]` (timeline with the bound tuple at each stage), `/dashboard/scans`, decision detail component. DoD: an analyst can trace one file from session to replica; every page has loading, empty and error states. Commit: `feat/dashboard): overview, files and decisions`.

P34 — Dashboard: review, policies, integrity, audit, access. `/dashboard/review`, `/dashboard/policies` (JSON diff between versions), `/dashboard/integrity`, `/dashboard/audit`, `/dashboard/access`. DoD: review flow inserts a superseding decision that still passes promotion

checks; integrity page shows chain and checkpoint status. Commit: feat(dashboard): review, policies, integrity, audit, access.

P35 — Security corpus and full test matrix. tests/fixtures/generate.ts (all classes, EICAR assembled at runtime, Mitra-generated polyglots with inert payloads, small bombs), manifest.csv, remaining API security tests (dos-01 to dos-06), security-matrix.csv emitted in CI. DoD: all 80 tests pass or are documented misses; corpus frozen with hashes. Commit: test(security): complete corpus and matrix.

P36 — Performance testing. k6 2.2 scripts for C0–C3, resource logger, full grid locally, reduced grid in the cloud, CSV and plots. DoD: perf-01 to perf-08 data collected; targets confirmed or revised in writing. Commit: test(perf): load and resource measurements.

P37 — Hardening and production-like notes. Image digest pinning, pnpm audit --prod, Trivy scan of images, seccomp review, dependency update policy, Level C documentation (Fargate, RDS, account-per-zone, KMS, compliance-mode Object Lock). DoD: zero high-severity findings in pnpm audit and Trivy; Level C documented with cost. Commit: chore(security): hardening and Level C notes.

P38 — Research evaluation and evidence. H1 configuration sweep, H2 chaos invariant, H3 from P32, H4 from P29, H5 from P36; statistics scripts; make reproduce; evidence folder with screenshots, CloudTrail exports, logs. DoD: one command regenerates every table and figure. Commit: docs(evaluation): reproducible experiments.

P39 — Documentation, demonstration and paper. README quick start (timed under 15 minutes), integration guide, runbook per alert, docs/openapi.json, demo script, paper draft. DoD: a new developer completes the quick start unaided; tagged v1.0.0. Commit: docs: release documentation.

2.3 Failure matrix (fail-closed, applies from P18 onward)

Failure	State	Detail
Database unavailable at upload	Upload refused 503	Nothing stored; no orphan object because the DB transaction precedes the response and the object expires in 7 days
Database unavailable mid-scan	Job re-queued by reaper	No result, no decision
Scanner (clamd) unavailable	ERROR / SCANNER_UNAVAILABLE, 3 retries, then stays ERROR	Never ALLOW
Scanner timeout	ERROR / SCAN_TIMEOUT ×3 then QUARANTINE	Slow files go to review
Scanner limit exceeded	QUARANTINE / SCANNER_LIMIT_EXCEEDED	Or BLOCK per policy

Failure	State	Detail
Unknown or undetermined type	QUARANTINE / TYPE_UNDETERMINED	
Detector disagreement	QUARANTINE / DETECTOR_DISAGREEMENT	
Hash mismatch at promotion	BLOCK / HASH_MISMATCH	CRITICAL audit, metric
Version missing or mismatch	BLOCK / VERSION_MISMATCH	
Result identity mismatch	BLOCK / RESULT_IDENTITY_MISMATCH	Rule R1
Required check missing	ERROR / REQUIRED_CHECK_MISSING	Rule R2
Storage write failure (clean)	Promotion job retries; decision stands	File stays PROMOTING
Storage write failure (quarantine)	Upload 503	
Encryption failure or KEK unavailable	Promotion job retries; never promotes plaintext	
Policy unavailable	Session 409 NO_ACTIVE_POLICY	
YARA failure (binary missing, rule compile error)	ERROR on yara.rules	Build fails first
Archive limit or ambiguity	BLOCK	
Encrypted content	BLOCK / ENCRYPTED_CONTENT	
Replication failure	Clean object remains valid; job retries up to 24 h; alert	
GCS unavailable	Same as above	
Audit insert failure	The surrounding transaction rolls back	No unaudited transition
Chain verification fails	Alert AuditChainBroken; uploads continue	Detectable, not preventable
Signatures stale > 7 days	ERROR / SCANNER_UNAVAILABLE	
Human review ALLOW	Still passes promotion verification	

Part 3 — Compatibility and documentation verification matrix

Every row was checked on 22 September 2026 against the source in the last column: the npm registry JSON for versions, engines and licence, and official documentation or repository source for behaviour. Rows marked UNVERIFIED must be re-checked in the phase that first uses them before any instruction is followed.

3.1 Runtime and tooling

Item	Verified version	Node 24	Licence	Notes	Source
Node.js 24	Active LTS; maintenance from 20 Oct 2026; EOL 30 Apr 2028	—	MIT-style	Node 26 is Current, LTS from 28 Oct 2026	nodejs.org releases
pnpm	12.5.1	yes	MIT	Native executable; Corepack still bundled in Node 24, removed in 25+	pnpm installation , Corepack
TypeScript	6.0.3 pinned (7.0.2 exists; no programmatic API yet)	yes	Apache-2.0	typescript-eslint peer <6.1.0	TS 7.0 announcement
ESLint	10.11.0; flat config only	≥ 20.19	MIT	ESLint 9 EOL 6 Aug 2026	ESLint v10
typescript-eslint	8.70.1	yes	MIT	peer eslint ^8.57 ^9 ^10	dependency versions
eslint-plugin-boundaries	7.2.0	≥ 18.18	MIT	Flat-config usage documented; ESLint 10 support not stated (UNVERIFIED, test in P1)	npm registry

Item	Verified version	Node 24	Licence	Notes	Source
Vitest	5.0.1	^22.12 ^24 ≥26	MIT	clearMocks default true; strict locators	Vitest 5 blog
tsx	4.23.15	yes	MIT	Dev only	npm registry
@types/node	24.13.6 (Node 24 line)	—	MIT	Pin the 24.x line	npm registry
Docker Compose	v2 (spec)	—	Apache-2.0	deploy.resources.limits applied by docker compose up; secrets file mounts; read_only, cap_drop, security_opt, tmpfs all in the spec	Compose deploy, services, secrets

3.2 API service

Package	Version	Node 24	Licence	Notes	Source
fastify	5.12.5	tested 20/22/24/26	MIT	Fastify 6 alphas exist; 6 will drop Node 20/22	Fastify LTS
@fastify/type-provider-zod	1.0.0	yes	MIT	peer fastify ^5.5, zod ≥ 4.2, @fastify/swagger ≥ 9.5.1; unscoped fastify-type-provider-zod 7.0 also exists, not chosen	npm registry
zod	4.6.5	yes	MIT	v4 API: z.email(),	zod v4 changelog

Package	Version	Node 24	Licence	Notes	Source
				<code>z.uuid()</code> , <code>z.strictObject()</code> , error not message	
@fastify/rate-limit	11.2.0	yes	MIT		npm registry
@fastify/helmet	13.1.1	yes	MIT	helmet ^8	npm registry
@fastify/cors	11.3.0	yes	MIT		npm registry
@fastify/cookie	11.1.2	yes	MIT		npm registry
@fastify/swagger	9.8.2	yes	MIT	OpenAPI 3.1 output	npm registry
pino / pino-pretty	10.3.1 / 13.1.3	yes	MIT		npm registry
@prometheus-io/client	0.16.1	^22 ^24 ≥26	Apache-2.0	Replaces deprecated prom-client	npm registry
jose	6.2.12	yes (WebCrypto Ed25519)	MIT	EdDSA and Ed25519 alg names supported	jose README
argon2	0.45.1	≥ 16.17; prebuilt Node- API binaries	MIT	Fallback @node- rs/argon2 2.2.1	node-argon2
kysely	0.29.6	≥ 22	MIT		npm registry
pg	8.23.0	yes	MIT		npm registry
node-pg-migrate	9.0.0	≥ 20.11; ESM	MIT	Plain SQL migrations supported	npm registry

3.3 Scanner and file handling

Item	Version	Node 24	Licence	Notes	Source
------	---------	---------	---------	-------	--------

Item	Version	Node 24	Licence	Notes	Source
file-type	22.1.1	≥ 22; ESM-only	MIT	API is <code>fileTypeFromBuffer</code> etc.; 2026 ZIP-bomb and ASF advisories fixed in current line	file-type readme
yauzl	3.4.0	yes	MIT	Maintained (June 2026)	npm registry
@zip.js/zip.js	2.17.0	≥ 18	BSD-3	Alternative	npm registry
sharp	0.35.4	≥ 20.9; libvips ≥ 8.18.6 prebuilt	Apache-2.0	pnpm must install optional deps	sharp install
ClamAV image	clamav/clamav:1.4.6 (LTS to 15 Aug 2027); 1.5.4 is regular	—	GPLv2	CLAMD_CONF_<Option> env overrides; <code>clamdcheck.sh</code> health; 3–4 GiB RAM	ClamAV Docker , EOL
clamd protocol	INSTREAM framing, <code>stream: OK</code>	—	—	z or n prefix mandatory for INSTREAM	clamd protocol , clamd.8
clamd.conf options	All eleven names used exist with the defaults quoted in the spec	—	—		clamd.conf.sample
clamscan npm	2.4.0 (Oct 2024)	yes	MIT	Not chosen; in-house client	npm registry
YARA-X	1.20.0 CLI; <code>yr scan --output-format ndjson</code> ; exit code 0/1 only	—	BSD-3	Install from GitHub release binary or <code>cargo install yara-x-cli</code> ; <code>pip install yara-x</code> is the	YARA-X CLI, installation

Item	Version	Node 24	Licence	Notes	Source
				Python binding, not the CLI	
@virustotal/yara-x npm	1.20.0 (WASM)	yes	BSD-3	Fallback; no production statement	npm registry
qpdf, file (libmagic)	Distro packages in the scanner image (Alpine qpdf, file)	—	Apache-2.0, BSD-2	Versions resolved at image build; pin the Alpine base digest	—
Magika, PolyFile	1.0.3 (pip) / 0.6.0 (pip)	—	Apache-2.0	Optional, advanced only	Magika , PolyFile

3.4 Storage, cloud SDKs and emulators

Item	Verified fact	Status	Source
MinIO	Repository archived April 2026; community distributed as source only; minio/minio on Docker Hub returns 404; last release Oct 2025	Not usable	MinIO README , releases
LocalStack Community	localstack/localstack:2026.08.3; PutObject IfNoneMatch since 3.7.0, IfMatch since 4.0.3; S3 in the free tier	Chosen; IAM enforcement in Community: VERIFICATION REQUIRED (P2) ; Object Lock coverage UNVERIFIED	v3.7.0 , S3 docs
SeaweedFS	4.45; versioning, Object Lock, conditional headers; If-None-Match: * bug on versioned buckets fixed Jan 2026	Fallback	S3 versioning wiki
fake-gcs-server	1.56.1; JSON-API ifGenerationMatch,	Chosen (JSON only)	upload.go

Item	Verified fact	Status	Source
	generations, declared CRC32C honoured; XML path not		
@aws-sdk/client-s3	3.1137.0; PutObjectCommand accepts IfNoneMatch, IfMatch, ChecksumAlgorithm: 'SHA256', returns VersionId, ChecksumSHA256; GetObjectCommand accepts VersionId, ChecksumMode	Verified from SDK source	models_0.ts
@aws-sdk/credential-providers	fromTemporaryCredentials({params: {RoleArn, DurationSeconds}})	Verified	README
@aws-sdk/client-ssm, client-kms	GetParameterCommand({Name, WithDecryption}); GenerateDataKeyCommand({KeyId, KeySpec: 'AES_256', EncryptionContext})	Verified	SDK source
@google-cloud/storage	8.2.0; Node ≥ 22; file.save(data, {preconditionOpts: {ifGenerationMatch: 0}, validation: 'crc32c', metadata})	Verified from source	file.ts
google-auth-library	11.1.0; external-account config with AWS credential source reads AWS_* env vars before IMDS	Verified	AIP-4117
S3 conditional writes	If-None-Match: * → 412 if exists, 409 on conflict; policy keys s3:if-none-match, s3:if-match,	Verified	conditional writes , enforce

Item	Verified fact	Status	Source
	s3:ObjectCreationOperation; enforcing breaks CopyObject		
S3 permissions	GetObject with versionId needs s3:GetObjectVersion ; permanent delete needs s3:DeleteObjectVersion; governance bypass needs s3:BypassGovernanceRetention	Verified	GetObject, policy actions
aws:PrincipalArn	Returns the role ARN for role sessions, not the session ARN	Verified	condition keys
SSM SecureString	With the AWS-managed aws/ssm key no explicit kms:Decrypt is needed	Verified	Parameter Store access
STS AssumeRole by IAM user	Trust policy principal = user ARN; user also granted sts:AssumeRole	Verified (whether the identity grant can be omitted same-account: UNVERIFIED; grant both)	switch-role permissions
GCS preconditions	ifGenerationMatch=0 → 412 if a live object exists; objectCreator lacks storage.objects.delete so cannot overwrite	Verified	objects.insert, IAM roles
GCS retention + versioning	Coexist; overwrite under retention → 403 retentionPolicyNotMet	Verified	Bucket Lock
WIF cred config	gcloud iam workload-identity-pools create-cred-config ... --aws --	Verified	WIF other clouds

Item	Verified fact	Status	Source
	service-account=... - -output-file=...; no key material in the file		

3.5 Infrastructure as code

Item	Verified fact	Source
Terraform	1.16.1; BUSL-1.1. OpenTofu 1.12.6 (MPL-2.0) as drop-in	Terraform releases , OpenTofu
AWS provider	6.58.0; aws_s3_bucket inline blocks deprecated (use separate resources); bucket_region attribute replaces region on the bucket; object_lock_enabled on aws_s3_bucket for new buckets	v6 upgrade guide
aws_s3_bucket_lifecycle_configuration	expiration { days } and expired_object_delete_mark er must be separate rules; filter required	provider docs
aws_s3_bucket_public_access_block	All four flags default false; set all true	provider docs
aws_iam_role	inline_policy, managed_policy_arns deprecated; use aws_iam_role_policy / attachment	provider docs
aws_iam_access_key	Secret written to state in plaintext unless pgp_key	provider docs; hence DEC-013
aws_ssm_parameter	SecureString value in state unless value_wo	provider docs
aws_budgets_budget, aws_cloudwatch_metric_alarm, aws_ce_anomaly_monitor/sub scription	Exist with the arguments used in P24	provider docs
Google provider	8.1.0 (7.x still patched); no	releases

Item	Verified fact	Source
	breaking change to the resources used	
google_storage_bucket	uniform_bucket_level_access, public_access_prevention = "enforced", versioning {enabled}, retention_policy {retention_period, is_locked}, soft_delete_policy {retention_duration_seconds}, lifecycle_rule	provider docs
google_iam_workload_identity_pool_provider	aws { account_id }, attribute_condition, attribute_mapping	provider docs
google_project	TF docs say an Organization is required; API allows none	Hence DEC-014
google_billing_budget	Needs billing_project + user_project_override = true with user ADC	provider docs

3.6 Frontend

Item	Version	Notes	Source
Next.js	16.3.5	Node ≥ 20.9; Turbopack default; next.config.ts supported, .cjs/.cts not; next build no longer lints; middleware renamed proxy; async params	installation , next.config
React	19.3.0		react.dev
Tailwind CSS	4.3.3 with @tailwindcss/postcss	postcss.config.mjs, @import "tailwindcss"	Tailwind + Next
shadcn CLI	4.21.0; pnpm dlx shadcn@latest init	Tailwind v4 and React 19 default; toast deprecated for sonner	shadcn Next , Tailwind v4 notes

3.7 Items that remain UNVERIFIED

Item	Why it matters	Verify in
LocalStack Community enforces IAM policies on S3 calls	Decides whether local IAM negative tests are meaningful	P2 spike
LocalStack Community Object Lock support	Local audit-bucket tests	P2 spike; otherwise audit-04 runs on AWS only
eslint-plugin-boundaries with ESLint 10	P1 lint gate	P1
k6 2.2.0 release date	None (version is current)	—
Terraform creating a parentless <code>google_project</code>	Avoided by DEC-014	—
Same-account AssumeRole without identity-policy grant	Avoided by granting both	—
Exact MinIO release that fixed <code>If-None-Match: *</code>	Moot after DEC-002	—
Whether the S3 SHA-256 full-object checksum applies to multipart	Moot: multipart disabled	—

Part 4 — Risk register

Twenty-two risks, technical and research. Probability and impact are Low, Medium or High. Status is OPEN until the named phase closes it. This table lives on as `docs/risk-register.md` from P0 and is updated whenever a phase changes it.

ID	Risk	Prob.	Impact	Mitigation	Detection	Fallback	Status
R-01	Local S3 emulator (LocalStack) diverges from S3 on version IDs, <code>If-None-Match</code> or checksums	M	H	P2 assumption spike runs before any storage code	Spike failures	SeaweedFS; or develop against a real AWS bucket in dev from P9	OPEN until P2

ID	Risk	Prob.	Impact	Mitigation	Detection	Fallback	Status
R-02	LocalStack Community does not enforce IAM, so local privilege-separation tests prove nothing	H	M	DEC-003: local separation by credentials only; real tests on AWS in P29	P2 check	SeaweedFS identities for local enforcement	OPEN until P2
R-03	ClamAV needs 3–4 GiB; team laptops with 8 GB struggle	M	M	One lab machine runs clamd; ConcurrentDatabaseReload no; MaxThreads 4	OOM kills in docker compose ps	Point the scanner at a shared clamd over the LAN	OPEN until P14
R-04	Fail-open bug in decision or promotion code	L	H	Pure decision function; property test; SQL invariant after every suite; two reviewers on packages/decision-engine, packages/crypto, services/promotion	int-01	Revert the phase	OPEN, re-checked every phase
R-05	Accidental AWS	M	M	P24 before	Budget e-mail	terraformorm	OPEN until P24

ID	Risk	Prob.	Impact	Mitigation	Detection	Fallback	Status
	spend (compute, data events, NAT, KMS keys)			P25: budgets, zero-spend alert, billing alarm, anomaly detection, region restriction ; CI grep for forbidden resource types		destroy; cleanup script	
R-06	New AWS account on the Free plan closes at 6 months	M	M	Create the account at P24, not P0; calendar reminder at month 5; upgrade to Paid with budgets in place	Warning e-mails at 50/25/10 % credits and 15/7/2 days	Export data with cloud-cleanup before closure	OPEN
R-07	Workload Identity Federation configuration stalls	M	L	Time-boxed spike in P26 with the documented create-cred-config -aws path; env-var	Token exchange errors	Executable-sourced credentials; never a key file	OPEN until P26

ID	Risk	Prob.	Impact	Mitigation	Detection	Fallback	Status
				credential source verified			
R-08	KEK loss	L	H	Two offline copies held by two people; restore drill in P28	Drill failure	None: files are unrecoverable, state this in the runbook	OPEN
R-09	TypeScript or ESLint toolchain drift (TS 7 API, ESLint 10)	M	L	Pin TS 6.0.3 and typescript-eslint 8.70; Renovate with grouped PRs and CI	CI failure	Alias typescript@npm:@typescript/typescript6	OPEN until P1
R-10	Upload-path library vulnerabilities	L	M	No multipart parser at all; raw body stream; pnpm audit --prod and Trivy in CI	CI	Patch and redeploy	Mitigated by design
R-11	Scanner container compromised by a hostile file	M	M	Read-only root, non-root, no egress, cap_drop ALL, SCANNER_ROLE cannot write clean or	Unexpected egress attempts, AccessDenied in CloudTrail	Rebuild container; re-scan affected files	Mitigated by design; tested in P22, P29

ID	Risk	Prob.	Impact	Mitigation	Detection	Fallback	Status
				insert decisions			
R-12	Race tests are flaky	M	M	Deterministic hook points in the promoter for the harness, plus randomised runs; 1,000 trials; report intervals	CI variance	Report both deterministic and random results separately	OPEN until P32
R-13	The four unread papers already cover the claimed gap	M	H	P0 reading list; claims phrased "to the best of our knowledge"; measurement and artifact stand regardless	Supervisor review	Reframe as reproduction and extension	OPEN until P0
R-14	Corpus built by the same people who built the checks (construct validity)	H	M	Classes derived from FUSE, FUEL, WSTG, ZipDiff; one member writes fixtures blind;	Peer review	State as limitation	OPEN until P35

ID	Risk	Prob.	Impact	Mitigation	Detection	Fallback	Status
				misses reported			
R-15	Scope creep into CDR, ML, sandbox, Kubernetes	H	M	MVP exclusion list; supervisor sign-off for additions; P37 is the only "extra" phase	PR review	Cut advanced items	OPEN
R-16	Next.js dashboard becomes a second backend holding secrets or logic	M	M	DEC-004 constraints; dashboard image scanned for secrets; Route Handlers only forward the JWT	Code review; gitleaks on the image	Replace with static export	OPEN until P31
R-17	GuardDuty or KMS enabled by mistake in the demo	L	L	Optional resources in separate Terraform files not applied by default	Budget	Disable	Mitigated
R-18	Performance targets unmet on laptops	M	L	Targets are declared before measurement and	P36 data	Revise targets with justification	OPEN until P36

ID	Risk	Prob.	Impact	Mitigation	Detection	Fallback	Status
				may be revised in writing; report ratios			
R-19	LocalStack image size and start time slow CI	M	L	SERVICES=s3; cache image; SeaweedFS if CI time exceeds 10 minutes	CI duration	SeaweedFS	OPEN until P2
R-20	Windows host path and line-ending issues in Docker bind mounts and scripts	M	L	.gitattributes forces LF; scripts run inside containers ; WSL 2 backend	Script failures	Run scripts through pnpm wrappers	OPEN until P1
R-21	Signature database rate-limited or blocked by the ClamAV CDN	L	M	freshclam only, Checks 12; one private mirror for the team if several machines	429/403 in freshclam logs	Mount a shared signature volume	OPEN until P14
R-22	Google project creation blocked (no billing, quota)	L	M	DEC-014: create by hand first; Always Free needs a billing account	gcloud errors	Skip GCS until resolved; replication is asynchronous and optional	OPEN until P26

ID	Risk	Prob.	Impact	Mitigation	Detection	Fallback	Status
				with a card		per policy	

Part 5 — Final implementation order

Thirty-nine phases in five tracks; the local MVP exists at the end of P23 (about week 13), the cloud MVP at P30, and the research artifact at P38. Dashboard phases run in parallel from P31 without blocking anything. Estimates assume three to four students part-time and are re-planned after P10.

5.1 Order and dependencies

flowchart LR

```

A[Track 1<br/>P0-P5 foundation] --> B[Track 2<br/>P6-P12 ingest]
B --> C[Track 3<br/>P13-P23 analysis,<br/>decision, promotion]
C --> D[Track 4<br/>P24-P30 clouds,<br/>metrics]
D --> E[Track 5<br/>P32, P35-P39<br/>research + release]
C -. -> F[Dashboard<br/>P31, P33, P34]
F -. -> E

```

#	Phase	Track	Blocked by	Est.	Milestone
0	Architecture freeze	1	—	1 wk	Decisions closed
1	Repository and monorepo	1	0	2 d	
2	Compose and storage spike	1	1	3 d	OPEN-2 closed
3	Schema and migrations	1	2	4 d	
4	Config and secrets	1	3	2 d	
5	Fastify foundation, health	1	4	2 d	First bootable API
6	API keys	2	5	2 d	
7	Users, JWT, RBAC	2	6	3 d	
8	Policy engine and sessions	2	7	4 d	
9	Storage provider,	2	2, 8	3 d	

#	Phase	Track	Blocked by	Est.	Milestone
	quarantine				
10	Streaming upload	2	9	4 d	Upload lands in quarantine with a version ID
11	Validators	2	10	4 d	
12	Artifact identity	2	11	2 d	
13	Job queue and worker	3	12	3 d	
14	ClamAV	3	13	4 d	EICAR blocked
15	YARA-X	3	14	2 d	
16	Archive inspection	3	15	5 d	
17	Findings and format checks	3	16	4 d	
18	Decision engine	3	17	4 d	
19	Envelope encryption	3	18	3 d	
20	Bound promotion, clean storage	3	19	5 d	Local end-to-end lifecycle
21	Audit chain completion	3	20	3 d	
22	Local privilege separation	3	21	3 d	
23	Integration, chaos, invariant	3	22	4 d	Local MVP
24	AWS hygiene and budgets	4	23	2 d	
25	AWS storage	4	24	5 d	Real S3

#	Phase	Track	Blocked by	Est.	Milestone
	and IAM (Terraform)				lifecycle
26	GCS and federation (Terraform)	4	25	4 d	
27	Replication service	4	26	3 d	
28	Cross-cloud checkpoints, restore	4	27	3 d	
29	Cloud IAM negative tests	4	28	3 d	H4 data
30	Metrics and alerts	4	29	3 d	Cloud MVP
31	Dashboard foundation	D	7	3 d	parallel
32	Baseline promoters and race harness	5	25	5 d	H3 data
33	Dashboard: overview, files, decisions	D	31, 21	5 d	parallel
34	Dashboard: review, policies, integrity, audit, access	D	33, 28	5 d	parallel
35	Corpus and full matrix	5	30	4 d	80 tests
36	Performance	5	35	4 d	H5 data
37	Hardening, Level C	5	36	3 d	
38	Research evaluation	5	32, 36, 29	5 d	make reproduce

#	Phase	Track	Blocked by	Est.	Milestone
39	Documentation, demo, paper	5	38, 34	2 wk	v1.0.0

Critical path: 0 → 5 → 10 → 12 → 13 → 20 → 23 → 25 → 30 → 35 → 38 → 39, about 24 weeks. If time runs short, cut in this order: P37 Level C notes, Grafana panels in P30, /dashboard/access in P34, image CDR (never scheduled). Never cut P22, P29, P32 or P38: they are the research.

5.2 Git strategy

Rule	Detail
Default branch	main, protected: CI required, one review (two for packages/decision-engine, packages/crypto, services/promotion, infrastructure/), linear history
Phase branch	phase/<nn>-<slug> from main, e.g. phase/10-streaming-upload
Commits inside a phase	Small, Conventional Commits (feat, fix, test, chore, docs, infra); each commit compiles
Merge	Squash-merge with the phase commit message from Part 2; tag phase-<nn> on main
Rollback point	git revert <squash-sha> restores the previous phase; migrations get a paired down file so the database can follow
Secrets	gitleaks pre-commit hook and CI; .env, secrets/, *.tfstate, *.json credential configs in .gitignore
Terraform state	Local file under infrastructure/*/state/ (git-ignored) for the demo; remote state is Level C
Evidence	docs/evidence/<phase>/ committed with screenshots and CSVs, never raw logs with secrets

5.3 Phase checkpoint template

Every phase ends with this list filled in and pasted into the pull request:

- ☐ Requirement implemented as stated in the phase contract
- ☐ pnpm typecheck and pnpm lint pass
- ☐ pnpm test passes; new tests named in the contract exist

- ☐ Security test(s) for the phase pass
- ☐ Configuration verified with the phase's verification commands and expected output
- ☐ Documentation updated (docs/, ADR if a decision changed, decision and risk registers)
- ☐ No known blocker; UNVERIFIED items listed for the next phase
- ☐ Squash commit created with the phase message; tag applied

5.4 Evidence collection plan (per phase)

Phase	Evidence to save under docs/evidence/	Paper section
P2	Spike output showing version IDs and 412 on second put	Implementation
P10	HeadObjectVersion output and the matching file_versions row	Design: identity
P14	EICAR scan log stream: Eicar-Test-Signature FOUND and the BLOCK record	Evaluation H1
P16	arc-02 timing and RSS chart	Evaluation H1
P18	Property-test output (10,000 cases, zero ALLOW on ERROR)	Design: fail-closed
P20	toctou-01-04 outputs; a HASH_MISMATCH decision record	Evaluation H3
P21	audit/verify output before and after tampering	Design: audit
P23	Chaos run summary with invariants.sql result	Evaluation H2
P25	terraform plan summary; bucket policy JSON; CloudTrail AssumeRole events	Deployment
P26-27	GCS object listing with generation; replicator 403 on read-back	Multi-cloud
P29	Blast-radius CSV; CloudTrail AccessDenied export	Evaluation H4
P30	Grafana screenshots of the alert drill	Observability

Phase	Evidence to save under docs/evidence/	Paper section
P32	H3 table: unscanned promotions per promoter per window, with intervals	Evaluation H3
P33–34	Dashboard screenshots: file timeline, decision detail, integrity page	System overview
P35	security-matrix.csv	Evaluation H1
P36	perf CSVs and plots	Evaluation H5
P38	make reproduce log	Reproducibility

5.5 Ready for Phase 0

When you say **START PHASE 0**, you will receive only Phase 0's full contract: the ADR set to write, the threat model and taxonomy templates, the decision and risk register files, the reading list, the exact repository bootstrap that P1 will build on, verification steps, and the checkpoint. Before that, three answers are useful but not blocking: OPEN-1 (PostgreSQL 18 or 16), OPEN-2 (LocalStack or SeaweedFS, which P2 can settle), and OPEN-3 (the two missing documents).